PSEB / ATOMCAMP DEPLOY AI BOOTCAMP — TECHNICAL REPORT

# Client-Side Attacks, Payloads & Career Paths

**Author:** Zahid Ullah | **Instructor:** Waseem Abbas Khan | **Date:** November 9, 2026 | **Module:** S08

| | |
|---|---|
| **Target Environment:** | Isolated VMware Enterprise Lab (pfSense 2.6.0 Routed) |
| **Attacker Host:** | Kali Linux 2024.x (10.50.20.10 / VMnet3 Offensive Security) |
| **Target Workstation:** | Windows 10 Pro 64-bit (10.50.10.21 / VMnet2 Enterprise LAN) |
| **Regulatory Authority:** | Authorized Laboratory Testing under Pakistan PECA 2016 Permitted Scope |
| **Curriculum Outcomes:** | Outcomes 1-7: Malware Classification, Phishing, Staged Payloads, UAC Bypass, Tunneling, Dark Web & Career Roadmap |

## 1. Executive Summary & Scope of Assessment

Modern perimeter defenses actively filter and reject unsolicited inbound network connections. Consequently, adversaries and red team practitioners rely heavily upon client-side operations where code execution is initiated from within the internal protected network. This technical report provides a rigorous academic and empirical evaluation of client-side payloads, malware classification, user interaction deciders, Windows access token dynamics, Dark Web routing architecture, and privilege elevation within an isolated dual-homed virtual laboratory.

> **LABORATORY INTEGRITY & AUTHORIZATION STATEMENT:** All testing and payload executions were conducted in a strictly isolated, dual-subnet virtual environment with no external routable connectivity. All actions were authorized for research and training under Pakistan's Prevention of Electronic Crimes Act (PECA 2016).

## 2. Task 1: Comprehensive Malware Taxonomy & Behavioral Analysis

Modern defensive architectures require granular knowledge of malware operational behaviors, propagation mechanisms, and defensive countermeasures. The matrix below presents the 9 primary malware classifications with real-world exemplars and mitigations.

| Family | Spread Vector | Real-World Exemplar | Mechanism of Action | Primary Defense |
|---|---|---|---|---|
| **Virus** | File transfer, host executable infection | Melissa (1999), Stuxnet LNK | Appends malicious code to benign host executables; triggers on host run. | Antivirus heuristics, File Integrity Monitoring (FIM). |
| **Worm** | Network flaws, autonomous scan | WannaCry (2017), Conficker | Self-replicates across subnets utilizing unpatched network vulnerabilities. | Network micro-segmentation, rapid vulnerability patching. |
| **Trojan** | Social engineering, fake utilities | Emotet, Zeus Banking Trojan | Masquerades as authentic software while deploying stealth background payloads. | Application Control (WDAC/AppLocker), EDR heuristics. |
| **Ransomware** | Phishing, RDP compromise | LockBit 3.0, Conti, Ryuk | Encrypts files via asymmetric keys, demanding payment for private decryptor. | Immutable offline backups, canary file detection, least privilege. |
| **Spyware** | Bundled installers, rogue plugins | Pegasus, Agent Tesla, FinFisher | Harvests keystrokes, webcam feeds, credentials, and exfiltrates silently. | Egress filtering, browser policy enforcement, EDR telemetry. |
| **Adware** | Deceptive bundle installers | Superfish, Fireball | Hijacks browser search engines and forces unwanted pop-up advertisements. | Secure Web Gateways, ad-block policies, enterprise browser control. |
| **Rootkit** | Kernel exploits, signed drivers | TDSS / Alureon, Sony BMG | Hooks kernel syscalls and SSDT to hide files, network sockets, and processes. | UEFI Secure Boot, Driver Signature Enforcement, VBS. |

| | | | | |
|---|---|---|---|---|
| **Botnet** | Credential spray, automated bots | Mirai (IoT), Necurs, Trickbot | Subjugates infected hosts into an orchestrated C2 network for DDoS or spam. | Egress DNS sinkholing, Network Intrusion Detection (NIDS). |
| **Fileless** | RAM injection, LOLBins (PowerShell) | PowerShell Empire, Poweliks, Cobalt Strike | Executes script payloads directly in volatile memory without dropping PE files on disk. | AMSI runtime scanning, PowerShell CLM, Script Block Logging. |

### 2.1 The Decisive Role of User Interaction in Client-Side Attacks

User interaction serves as the decisive security bypass switch: **(1) Firewall Egress Traversal:** The connection originates from inside, traversing perimeter firewalls; **(2) Security Token Inheritance:** The payload executes within the user's active session, inheriting their access privileges; **(3) Trust Exploitation:** The user's action diminishes rule-based heuristic alerts by mimicking standard user behavior.

### 2.2 Deep-Dive: Fileless Malware & Living-off-the-Land Binaries (LOLBins)

- **PowerShell (powershell.exe):** Downloads and reflects payloads into memory without writing to disk.
- **Certutil (certutil.exe):** Abused via *-urlcache -split -f* to download and decode remote payloads.
- **MSHTA (mshta.exe):** Executes remote VBScript/JScript files directly from the web, bypassing browser execution checks.
- **BITSAdmin (bitsadmin.exe):** Initiates asynchronous, throttling-resilient background downloads mimicking OS updates.

*Defensive Mitigation:* Requires runtime behavioral inspection: Antimalware Scan Interface (AMSI), PowerShell Script Block Logging (Event ID 4104), and Constrained Language Mode (CLM) enforced via WDAC.

### 2.3 Attack Vectors and the Human Layer: Real Phishing Case Study

Social engineering exploits predictable psychological tendencies (urgency, authority, curiosity). Vectors include Phishing (bulk emails), Spear Phishing (targeted research), Vishing (voice calls), Smishing (SMS), Pretexting, and physical tailgating.
**Case Study — Emotet Malicious Macro Campaign:** Attackers distributed fake invoice emails containing macro-enabled Word documents. Upon opening, the lure urged users to 'Enable Content', which executed an obfuscated VBA macro launching *powershell.exe -W Hidden -Enc*. PowerShell pulled the primary payload into RAM from a compromised host and injected it into *explorer.exe*. Defensive controls: Blocking internet macros via Mark-of-the-Web (MotW), enforcing DMARC, and AMSI runtime scanning completely neuter this attack chain.

## 3. Task 2: Payload Engineering, Execution Telemetry & Privilege Analysis

### 3.1 Comparative Analysis: Staged vs. Inline (Non-Staged) Payloads

Metasploit denotes payload architecture through forward slash notation (*windows/meterpreter/reverse_tcp* = staged) versus underscore notation (*windows/meterpreter_reverse_tcp* = inline). A staged payload generates an ultra-lightweight initial binary (stager: 355 bytes shellcode in a 7,168-byte PE). The stager's sole purpose is to initialize Winsock, connect back to the listener, allocate memory via *VirtualAlloc()*, and download the full 203,451-byte reflective DLL stage. An inline payload packages the entire reflective DLL (~200+ KB) inside the initial binary, eliminating secondary network transmission but increasing static binary footprint.

### 3.2 Laboratory Setup, Delivery & Listener Activation

Testing was conducted across two segmented subnets: Kali Linux (10.50.20.10) and Windows 10 (10.50.10.21) separated by pfSense. While Kali cannot ping Windows 10 due to Windows Defender Firewall dropping inbound ICMP, Windows 10 reaches Kali with round-trip latency <1 ms (TTL=63).

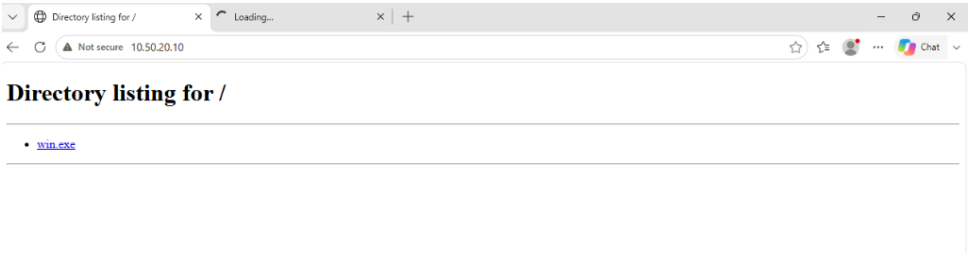



***Figure 2.1:*** *Payload delivery interface hosted via Python HTTP on Kali accessed from Windows 10 Edge.*

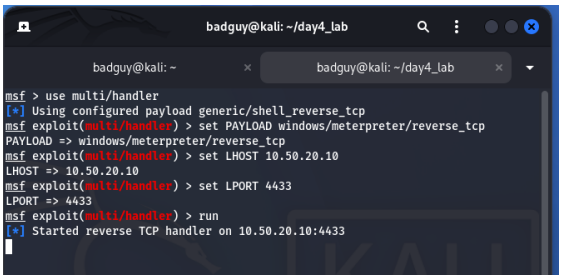



***Figure 2.2:*** *Metasploit multi/handler configured on 10.50.20.10:4433 listening for incoming callback.*

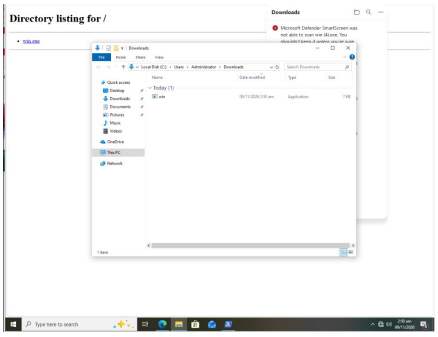



***Figure 2.3:*** *Target filesystem verification confirming download of win.exe in Downloads directory.*

## 3.3 Target Execution & Active Session Monitoring

Upon simulated execution on Windows 10, Task Manager confirmed the creation of the 32-bit container win.exe (consuming 1.0 MB RAM). The process immediately initiated a reverse TCP connection to port 4433, prompting Metasploit to transmit the 203,451-byte reflective DLL stage and establish Session 1.

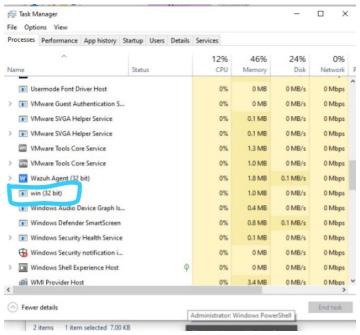



***Figure 2.4:*** *Windows Task Manager confirming active execution of 32-bit win.exe container.*

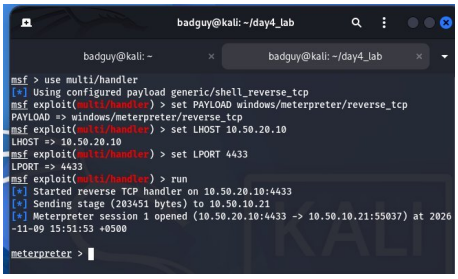



***Figure 2.5:*** *Metasploit console logging stage delivery (203,451 bytes) and Meterpreter Session 1 opened.*

## 3.4 Access Token Mechanics & Named Pipe Impersonation (Technique 1)

**Why UAC Blocks the First getsystem ('Access is denied'):**
Under Windows User Account Control (UAC), an administrative user operates with a filtered standard token (Medium integrity) by default. When running *getsystem* directly without an elevated token, the command returns: [-] priv_elevate_getsystem: Operation failed: Access is denied. This error confirms that UAC is functioning correctly as a security boundary: because the token is filtered, administrative privileges like *SeDebugPrivilege* and *SeImpersonatePrivilege* are stripped. Without them, SYSTEM cannot be obtained directly.

**Named Pipe Impersonation Sequence:**
In our verified testbed, the process ran under the domain administrative session (*SEC\Administrator*). Meterpreter successfully elevated via Named Pipe Impersonation (Technique 1):
1. Meterpreter creates a local Windows Named Pipe (\\.\pipe\...).
2. As an administrator, it creates and starts a temporary service running under *NT AUTHORITY\SYSTEM*.
3. The SYSTEM service connects to the listening named pipe.
4. Meterpreter invokes the Windows API *ImpersonateNamedPipeClient()*, duplicating the connecting SYSTEM access token to the thread.

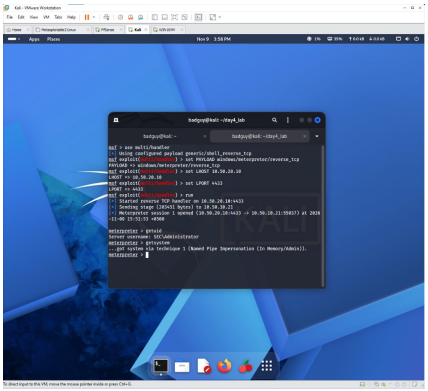


***Figure 2.6:*** *Verification of initial user identity (SEC\Administrator) and elevation to NT AUTHORITY\SYSTEM via Named Pipe Impersonation.*

## 3.5 Delivery Concepts & Legal Governance

• **WinRAR SFX Binding:** Malicious executables are bundled with legitimate utilities (e.g., Rufus, PDF readers). The SFX script silently extracts both files to %TEMP%, executing the decoy utility visually while running the payload invisibly in the background.
• **WAN Ingress Tunneling (LocalToNet/Ngrok):** Provides a public TCP relay address, enabling reverse TCP callbacks to traverse carrier-grade NAT (CGNAT) without exposing the attacker's physical IP address.
• **msfvenom LHOST Hostname Diagnostic:** When msfvenom rejects a tunneling hostname with *'Error: One or more options failed to validate: LHOST'*, resolving the domain via ping to its IPv4 address allows successful binary generation.
• **Legal Governance (Pakistan PECA 2016):** Section 3 (Unauthorized access to systems/data), Section 4 (Unauthorized copying/transmission of data), and Section 5 (Interference with data/systems) establish clear criminal penalties. All activities must be bound by signed Rules of Engagement (RoE) and asset owner authorization.

## 4. The Dark Web: Architecture, The Relay Model & Lawful Investigation

**The Three Layers of the Web:**
• *Surface Web:* Indexed and publicly accessible (news, blogs, search engines).
• *Deep Web:* Accessible via normal browsers but unindexed behind authentication or dynamic forms (webmail, cloud consoles, intranets; accounts for >90% of the web).
• *Dark Web:* Overlay networks requiring specialized protocols/software (Tor .onion, I2P eepsites).

**The Tor 3-Relay Circuit:**
[Client] ---> [Entry / Guard Node] ---> [Middle Relay] ---> [Exit Node] ---> [Destination]
• Entry Node knows the user's real IP, but not the destination.
• Middle Relay knows neither the client IP nor the destination.
• Exit Node knows the destination and sends traffic, but has no knowledge of the client IP.
*Security Consequence:* Because the exit node handles unencrypted destination traffic, malicious exit nodes can capture plaintext credentials unless end-to-end TLS (HTTPS) is enforced.

**Onion Addressing & Lawful Investigation:**
v2 addresses (16 characters) were deprecated due to brute-force enumeration risks; v3 addresses (56 characters, ed25519) provide cryptographically secure routing. Professional investigation (threat intel, brand protection, fraud research) must be conducted within an authorized, documented scope using dedicated isolated VMs (REMnux, FLARE VM) and the Tor Browser.

## 5. Task 3: Professional Career Statement & 90-Day Execution Roadmap

As a graduate of the PSEB / Atomcamp DEPLOY AI Cybersecurity Bootcamp, my career target is to serve as a **Security Operations Center (SOC) Analyst / Junior Penetration Tester**. By combining offensive insight into malware staging and access token mechanics with defensive detection engineering, I aim to protect enterprise infrastructures from sophisticated threats.

**Pakistani Job Market Realities:** Demand is growing rapidly across commercial banks, telecoms, federal agencies, and MSSPs. The primary bottleneck is not qualifications but tangible proof of competence: employers prioritize verifiable lab portfolios over paper certificates. Significant regional mobility exists in the Gulf region (UAE, Saudi Arabia) for certified practitioners who can communicate findings in business terms.

**Open-Source SOC with Wazuh:** Hands-on mastery of the Wazuh architecture (Agent forwards telemetry $ ightarrow$ Manager correlates rules $ ightarrow$ Indexer stores data $ ightarrow$ OpenSearch Dashboard visualizes alerts). Understanding threat intelligence distinction: retrospective IOCs (hashes/IPs), prospective IOAs (attacks in progress), and behavioral TTPs (adversary methods).

- **Industry Credential Pathway:** CompTIA Security+ (Months 1-2), Blue Team Level 1 / BTL1 (Months 3-4), and Practical Network Penetration Tester / PNPT (Months 5-6).
- **GitHub Portfolio Project 1 (Days 1-30):** Enterprise Multi-Subnet Virtual Cyber Range & pfSense Traffic Routing Documentation with Wazuh EDR integration.
- **GitHub Portfolio Project 2 (Days 31-60):** LOLBins Threat Hunting & Sigma Detection Repository (auditing Certutil, MSHTA, and PowerShell memory execution).
- **GitHub Portfolio Project 3 (Days 61-90):** Automated Windows Endpoint CIS Hardening & Audit Script (evaluating UAC levels, Script Block Logging, and disabling legacy protocols).

## 6. Evidence Repository Index

| Artifact Identifier | Type | Description & Phase |
|---|---|---|
| 01_network_verification.txt | Text Log | Bidirectional reachability across pfSense between Kali and Windows 10. |
| 02_msfvenom_payload_gen.txt | Text Log | Stager payload generation parameters and binary sizing metrics. |
| 02_payload_delivery_http.png | Visual Capture | Target accessing Python HTTP web server for payload acquisition. |
| 03_msf_handler_listen.png / .txt | Visual / Log | Metasploit multi/handler listener configuration on port 4433. |
| 04_payload_downloaded_windows.png | Visual Capture | Target filesystem verification in Windows 10 Downloads folder. |
| 05_task_manager_execution.png | Visual Capture | Target Task Manager confirming active win.exe (32-bit) process. |
| 06_meterpreter_session_established.png | Visual Capture | Stage delivery (203,451 bytes) and Session 1 opened on Kali. |
| 07_privilege_elevation_system.png / .txt | Visual / Log | Verification of SEC\Administrator session and Named Pipe Impersonation to SYSTEM. |